

Security and Access Control Document (SAD)

1. User Access & Authentication

IRVision AI implements a strict token-based authorization mechanism to protect confidential remote sensing data:

- **JSON Web Tokens (JWT):** Access is secured using signed HS256-hashed JWT tokens. The token is stored in the browser's localStorage and must be appended to the 'Authorization: Bearer ' header on all secured HTTP requests.
- **OAuth 2.0:** Single Sign-On (SSO) delegation using Google Accounts integration. The backend resolves the state callbacks securely and creates matching system credentials dynamically.

2. Data & Password Security

Security Area	Implementation Standard	Description
Password Hashing	Bcrypt (salt rounds = 12)	All user passwords are salted and hashed. Cleartext passwords are never saved in database layers.
Password Recovery	6-digit OTP Verification	Recovery codes expire in 10 minutes. Max 3 failed attempts before code invalidation.
API CORS Policies	Explicit Whitelisting	CORS origins only permit the frontend client (https://irvision-ai-client.onrender.com).
File Size Filtering	Max Size Limit (15MB)	Upload endpoints reject files larger than 15MB to prevent denial of service (DoS).
File Format Restrictions	Extension Whitelist	Only .png, .jpg, .jpeg, .tif, and .tiff file structures are processed by OpenCV.

3. Network Security & Hosting Constraints

All external API traffic is served over HTTPS/SSL. Render automatically manages certificate renewal. To prevent IP whitelist issues on MongoDB Atlas, database queries fallback to an encrypted local storage file if the network block list rejects Render's dynamic outgoing IPs.